

Security+ 5.1 · Security Considerations

Mestre CyberSec — PDF baseado na aula do Professor Messer · 5.1 — Security Considerations (4:51) · [vídeo original ↗](#) · [YouTube ↗](#)

Regulatório: GDPR (UE), HIPAA (saúde US), PCI-DSS (cartão), SOX (financeiro público), FERPA (educacional); legal issues (evidência, privacidade, investigação); industry standards (CIS, ISO, NIST).

Highlights que a prova cobra

- Cada indústria tem sua LEI: PCI-DSS pagamento, HIPAA saúde, SOX financeiro
- GDPR protege dados de UE-cidadãos INDEPENDENTE de onde a empresa está

Dicas de prova

- 'regulation protecting EU citizen data'=GDPR

Cenário clássico: 'empresa de healthcare nos EUA processa dado de paciente'=HIPAA.

Perguntas de treino (10 questões)

Gabarito no fim. Tenta responder SEM olhar.

1. Qual lei regula a proteção de dados pessoais na União Europeia?

- A) HIPAA
- B) GLBA
- C) GDPR
- D) SOX

2. HIPAA (Health Insurance Portability and Accountability Act) protege informações relacionadas a:

- A)** Dados financeiros
- B)** Dados educacionais
- C)** Informações de saúde protegidas (PHI)
- D)** Informações de defesa nacional

3. HIPAA, GLBA e GDPR protegem, respectivamente, dados de:

- A)** Saúde (US) / Financeiro (US) / Pessoais (UE)
- B)** Governo / Militar / Escolar
- C)** Cartão / Senha / Biometria
- D)** Nuvem / Rede / Endpoint

4. Cenário corporativo (Security Considerations): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.1), um analista avalia o seguinte requisito técnico: 'Cada indústria tem sua LEI: PCI-DSS pagamento, HIPAA saúde, SOX financeiro'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: Cada indústria tem sua LEI: PCI-DSS pagamento, HIPAA saúde, SOX financeiro...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

5. Cenário corporativo (Security Considerations): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.1), um analista avalia o seguinte requisito técnico: 'GDPR protege dados de UE-cidadãos INDEPENDENTE de onde a empresa está'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: GDPR protege dados de UE-cidadãos INDEPENDENTE de onde a empresa está...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

6. Cenário corporativo (Security Considerations): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.1), um analista avalia o seguinte requisito técnico: 'regulation protecting EU citizen data'=GDPR'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: 'regulation protecting EU citizen data'=GDPR...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

7. Cenário corporativo (Security Considerations): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.1), um analista avalia o seguinte requisito técnico: 'empresa de healthcare nos EUA processa dado de paciente'=HIPAA.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: 'empresa de healthcare nos EUA processa dado de paciente'=HIPAA....

8. Cenário corporativo (Security Considerations): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.1), um analista avalia o seguinte requisito técnico: 'Cada indústria tem sua LEI: PCI-DSS pagamento, HIPAA saúde, SOX financeiro'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: Cada indústria tem sua LEI: PCI-DSS pagamento, HIPAA saúde, SOX financeiro...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

9. Cenário corporativo (Security Considerations): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.1), um analista avalia o seguinte requisito técnico: 'GDPR protege dados de UE-cidadãos INDEPENDENTE de onde a empresa está'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: GDPR protege dados de UE-cidadãos INDEPENDENTE de onde a empresa está...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

10. Cenário corporativo (Security Considerations): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.1), um analista avalia o seguinte requisito técnico: 'regulation protecting EU citizen data'=GDPR'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: 'regulation protecting EU citizen data'=GDPR...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

GABARITO COMENTADO

- 1) C — GDPR.** GDPR (General Data Protection Regulation) é a regulamentação europeia que protege dados pessoais e privacidade de indivíduos na UE e EEE.
- 2) C — Informações de saúde protegidas (PHI).** HIPAA é legislação dos EUA que protege PHI (Protected Health Information) e estabelece padrões para segurança e privacidade de dados de saúde.
- 3) A — Saúde (US) / Financeiro (US) / Pessoais (UE).** HIPAA = saúde nos EUA; GLBA = dados financeiros nos EUA; GDPR = dados pessoais na União Europeia. São as leis de compliance que mais aparecem nas vagas de GRC.
- 4) A — Implementar a solução correspondente: Cada indústria tem sua LEI: PCI-DSS pagame.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.1 (Security Considerations): Cada indústria tem sua LEI: PCI-DSS pagamento, HIPAA saúde, SOX financeiro. As demais alternativas configuram
- 5) A — Implementar a solução correspondente: GDPR protege dados de UE-cidadãos INDEPEND.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.1 (Security Considerations): GDPR protege dados de UE-cidadãos INDEPENDENTE de onde a empresa está. As demais alternativas configuram viol
- 6) C — Implementar a solução correspondente: 'regulation protecting EU citizen data' =GD.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.1 (Security Considerations): 'regulation protecting EU citizen data'=GDPR. As demais alternativas configuram violações graves de conformid
- 7) D — Implementar a solução correspondente: 'empresa de healthcare nos EUA processa da.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.1 (Security Considerations): 'empresa de healthcare nos EUA processa dado de paciente'=HIPAA.. As demais alternativas configuram violações
- 8) C — Implementar a solução correspondente: Cada indústria tem sua LEI: PCI-DSS pagame.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.1 (Security Considerations): Cada indústria tem sua LEI: PCI-DSS pagamento, HIPAA saúde, SOX financeiro. As demais alternativas configuram
- 9) C — Implementar a solução correspondente: GDPR protege dados de UE-cidadãos INDEPEND.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.1 (Security Considerations): GDPR protege dados de UE-cidadãos INDEPENDENTE de onde a empresa está. As demais alternativas configuram viol
- 10) C — Implementar a solução correspondente: 'regulation protecting EU citizen data' =GD.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.1 (Security Considerations): 'regulation protecting EU citizen data'=GDPR. As demais alternativas configuram violações graves de conformid

